

TECHNICAL DETAIL

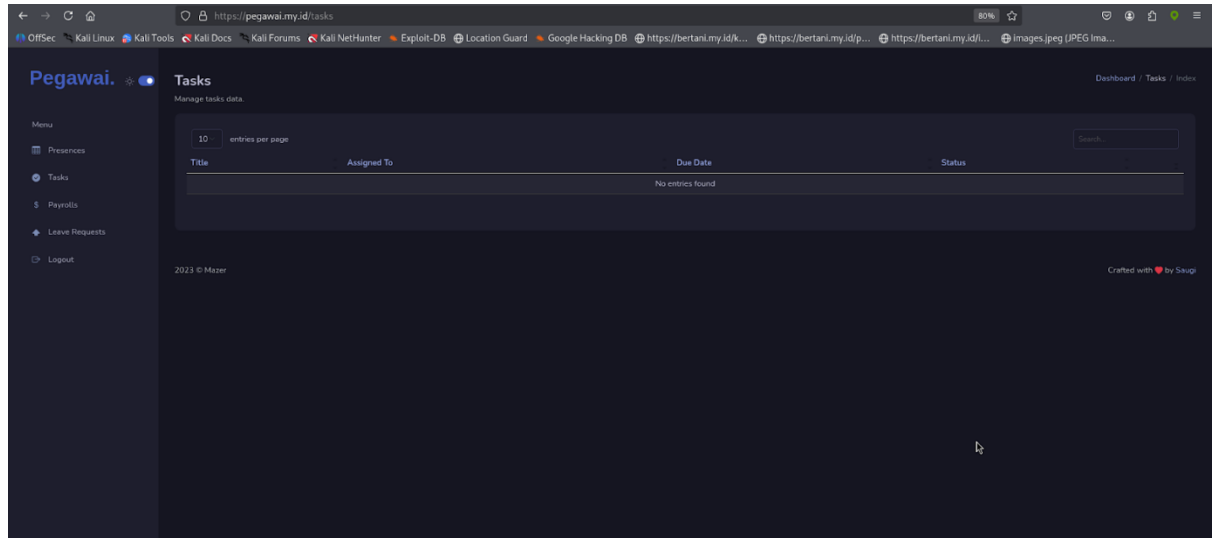
Title	Broken Access Control: Insecure Direct Object Reference (IDOR) on Task Details
Reporter	Daffa Rahadya Atmawiguna (rahadya.daffaa@gmail.com)
Date	2025-12-28
Affected Asset	https://pegawai.my.id/tasks/{id}
Severity	Medium
CVSS Score	5.3 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N)
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

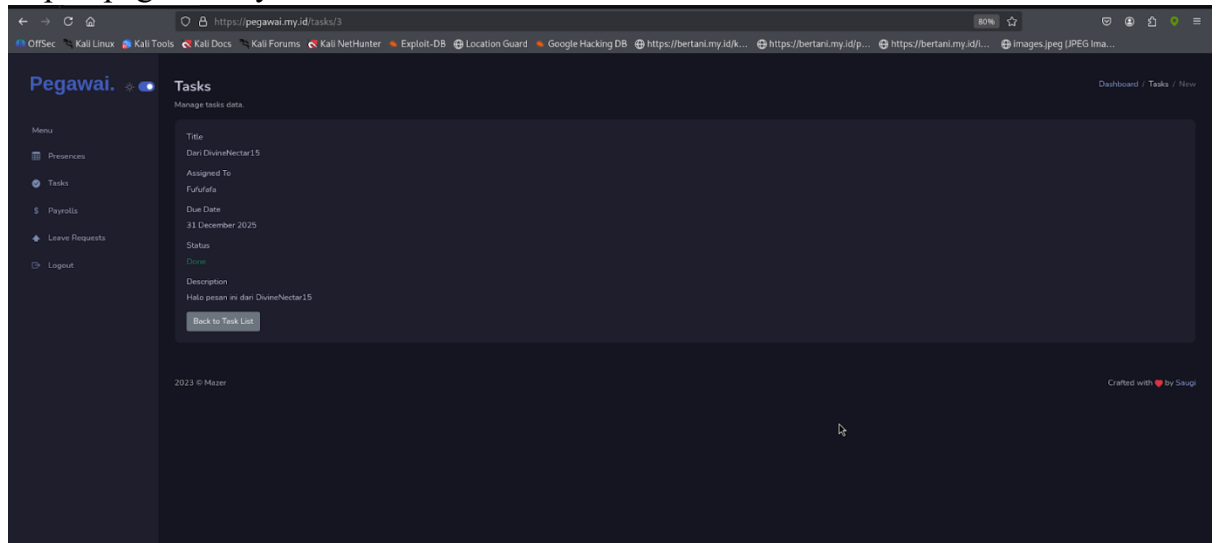
Ditemukan kerentanan Broken Access Control berjenis Insecure Direct Object Reference (IDOR) pada fitur rincian tugas (*Tasks*) di platform pegawai.my.id. Pengguna yang telah masuk dapat melihat detail tugas milik karyawan lain hanya dengan memodifikasi parameter ID pada URL. Hal ini terjadi karena aplikasi tidak melakukan verifikasi di sisi *server* apakah pengguna yang meminta data tersebut memiliki hak akses yang sah (sebagai pemilik tugas atau administrator) terhadap ID tugas yang dituju.

STEPS TO REPRODUCE

1. Login ke akun Anda yang memiliki role developer
2. Buka url <https://pegawai.my.id/tasks> disin terlihat tidak ada fitur untuk melihat tasks milik user lain



3. Lalu tambahkan `{id}` sebagai contoh disini saya masukan `id=3` di url menjadi <https://pegawai.my.id/tasks/3> maka anda bisa melihat tasks milik user lain.



EXPECTED RESULT

1. Sistem seharusnya melakukan pengecekan otoritas di sisi *server* untuk setiap permintaan akses ke ID objek tertentu.
2. Jika pengguna mencoba mengakses ID tugas yang bukan miliknya atau tidak berada dalam wewenangnya, sistem harus menolak akses dengan respons 403 Forbidden atau 404 Not Found.

ACTUAL RESULT

1. Pengguna dapat dengan bebas mengakses dan melihat data tugas milik orang lain hanya dengan mengganti angka ID di URL.
2. Informasi sensitif seperti judul tugas, nama penerima tugas, tanggal jatuh tempo, status, dan deskripsi tugas karyawan lain terekspos tanpa otorisasi.

IMPACT

1. Information Disclosure: Kebocoran rincian pekerjaan, instruksi kerja, atau data operasional sensitif milik karyawan lain dalam satu organisasi.
2. Privacy Violation: Pelanggaran privasi data antar pengguna yang dapat disalahgunakan untuk memantau beban kerja atau aktivitas rekan kerja tanpa izin.

RECOMMENDATION

1. Implementasi Object-Level Authorization: Pastikan setiap rute yang menerima parameter ID objek melakukan validasi kepemilikan atau hak akses pengguna di sisi *backend* sebelum mengembalikan data.
2. Penggunaan UUID: Pertimbangkan untuk mengganti penggunaan ID numerik yang berurutan dengan UUID (*Universally Unique Identifier*) guna menyulitkan penyerang dalam menebak ID objek secara acak

REFERENCES

1. **OWASP Top 10 - A01:2021 Broken Access Control:**
https://owasp.org/Top10/A01_2021-Broken_Access_Control/
2. **CWE-639: Authorization Bypass Through User-Controlled Key:**
<https://cwe.mitre.org/data/definitions/639.html>

